

Informe de Pentesting — Actividad A08

INSECUR S.A.

Table of Contents

Informe de Pentesting — Actividad A08

Cliente: INSECUR S.A. **Laboratorio:** TryHackMe **Asignatura:** Seguridad Aplicada a Sistemas de Información **Licenciatura en Sistemas de Información — Facultad de Informática y Diseño Docente:** Ing. Rodrigo Atilio Elgueta

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Enrique Pizarro
DNI	44538314
Username TryHackMe	enrique.pzrr
Email de contacto	pizarro123e@gmail.com
Sala de elección (Nivel 2)	Vulniversity
Branch en GitHub	pizarro-enrique
Fecha de inicio	07/10/2026
Fecha de cierre	08/10/2026

2. Pre-pentesting

Alcance del trabajo

El alcance de la intervención se limita exclusivamente a los entornos de laboratorio virtualizados provistos por la plataforma TryHackMe, conectados mediante VPN (OpenVPN) con una IP asignada dinámicamente por la plataforma para cada máquina. Se trabajaron las dos salas obligatorias del Núcleo (**Pentesting Fundamentals** y **Basic Pentesting**) y una sala de elección de Nivel 2 (**Vulniversity**). Quedan explícitamente excluidos del alcance cualquier sistema, red o activo que no sea provisto y autorizado por TryHackMe dentro de estas salas. No se realizó ninguna acción contra sistemas de producción, infraestructura real de INSECUR S.A. (ficticia) ni contra terceros.

Reglas de Enfrentamiento (ROE)

- Las pruebas se ejecutaron únicamente contra la/las IP(s) asignadas por TryHackMe para cada sala, verificadas antes de cada acción.
- Horario de trabajo: sesiones del 07/10/2026 al 08/10/2026, dentro del período habilitado por la cátedra.
- Técnicas prohibidas: ninguna técnica destructiva (denegación de servicio, borrado de datos) fue utilizada; el objetivo fue obtención de acceso y escalada de privilegios con fines de evaluación.
- Herramientas de fuerza bruta (Hydra) se limitaron en concurrencia (reducción de threads) para evitar saturar el servicio objetivo ante errores de conexión.
- Ante cualquier incidente de conectividad (caída de VPN, reinicio de la máquina objetivo con reasignación de IP) se documentó la situación y se repitió el paso afectado contra la nueva IP.

Autorización

Se declara que el presente trabajo se realizó bajo la autorización expresa de la cátedra “Seguridad Aplicada a Sistemas de Información” (FID-UCH), en el marco de la Actividad A08, utilizando exclusivamente los entornos de laboratorio de TryHackMe indicados en la guía oficial de la actividad. Cualquier acción fuera de este alcance queda fuera de esta autorización.

Metodología utilizada

Se siguió un enfoque alineado a las fases descritas por **PTES (Penetration Testing Execution Standard)** y la **OWASP Testing Guide** para el componente web, cubriendo: Pre-engagement, Reconocimiento, Escaneo, Enumeración, Explotación, Post-explotación y Reporte. Esta elección se justifica porque las salas trabajadas combinan servicios de red tradicionales (SSH, SMB) con una aplicación web vulnerable, por lo que un marco general (PTES) complementado con la guía específica de OWASP para la fase web permitió cubrir ambos frentes de forma ordenada.

3. Durante: Hallazgos por fase

H-01 — Credenciales SSH débiles (fuerza bruta exitosa)

Campo	Valor
Fase	Escaneo / Explotación
Descripción	Mediante Hydra se realizó un ataque de fuerza bruta contra el servicio SSH de la máquina de Basic Pentesting , utilizando el diccionario rockyou.txt. Se obtuvo la credencial válida <code>jan:armando</code> , lo que evidencia una política de contraseñas débil para una cuenta de usuario estándar.
Componente afectado	Servicio SSH (puerto 22)

Campo	Valor
Categoría (OWASP / CWE)	CWE-521 (Weak Password Requirements)
CVE	No aplica (falla de configuración, no de software)
CVSS estimado	Alto
Evidencia	Salida de Hydra registrada en <code>bitacora/hydra_jan.txt</code> ; captura de sesión SSH autenticada como <code>jan</code> .
Herramienta utilizada	Hydra
Impacto en la Tríada CIA	Confidencialidad, Integridad
Salvaguarda propuesta	Política de contraseñas robustas (longitud mínima, complejidad), bloqueo de cuenta tras N intentos fallidos, autenticación por clave pública únicamente, y/o MFA para accesos SSH.
Riesgo residual	Bajo

H-02 — Clave privada SSH expuesta y con permisos incorrectos

Campo	Valor
Fase	Post-explotación
Descripción	Desde la cuenta <code>jan</code> se localizó una clave privada SSH (<code>id_rsa</code>) perteneciente al usuario <code>kay</code> , accesible con permisos de lectura indebidos. Esto permitió extraer la clave para un ataque posterior offline.
Componente afectado	Sistema de archivos local (permisos de usuario <code>kay</code>)
Categoría (OWASP / CWE)	CWE-522 (Insufficiently Protected Credentials)
CVE	No aplica
CVSS estimado	Alto
Evidencia	Salida de <code>find/ls -la</code> mostrando permisos del archivo; copia de <code>id_rsa</code> documentada en la bitácora.
Herramienta utilizada	<code>find</code> , <code>ls</code> , <code>scp/cat</code>
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	Restringir permisos de archivos sensibles a <code>600</code> y propietario exclusivo; auditorías periódicas de permisos en <code>/home</code> .
Riesgo residual	Bajo

H-03 — Passphrase de clave SSH débil (crackeable offline)

Campo	Valor
Fase	Post-explotación
Descripción	La clave privada de kay estaba protegida por una passphrase. Utilizando <code>ssh2john</code> para convertir la clave a un hash crackeable y <code>john</code> con diccionario <code>rockyou.txt</code> , se obtuvo la passphrase en texto claro, permitiendo autenticarse como kay vía SSH.
Componente afectado	Clave privada SSH de kay
Categoría (OWASP / CWE)	CWE-521 (Weak Password Requirements)
CVE	No aplica
CVSS estimado	Alto
Evidencia	Salida de <code>john</code> con la passphrase recuperada; sesión SSH autenticada como kay usando la clave.
Herramienta utilizada	<code>ssh2john</code> , John the Ripper
Impacto en la Tríada CIA	Confidencialidad, Integridad
Salvaguarda propuesta	Exigir passphrases de alta entropía para claves privadas, o custodiarlas en un agente/HSM en lugar de archivos en disco.
Riesgo residual	Bajo

H-04 — Credencial sensible almacenada en archivo de respaldo + sudo sin restricciones

Campo	Valor
Fase	Post-explotación
Descripción	En el home de kay se encontró el archivo <code>pass.bak</code> , legible únicamente por su propietario, que contenía la contraseña real de la cuenta en texto plano. Adicionalmente, <code>sudo -l</code> mostró que kay tenía permisos de sudo sin restricciones (ALL), permitiendo escalar directamente a root.
Componente afectado	Archivo <code>pass.bak</code> ; configuración de <code>sudoers</code>
Categoría (OWASP / CWE)	CWE-256 (Plaintext Storage of a Password) / CWE-269 (Improper Privilege Management)
CVE	No aplica
CVSS estimado	Crítico
Evidencia	Contenido de <code>pass.bak</code> ; salida de <code>sudo -l</code> ; sesión como root tras <code>sudo su</code> .

Campo	Valor
Herramienta utilizada	cat, sudo
Impacto en la Tríada CIA	Confidencialidad, Integridad, Disponibilidad
Salvaguarda propuesta	Eliminar archivos de respaldo con credenciales en texto plano; aplicar principio de mínimo privilegio en sudoers, otorgando solo los comandos estrictamente necesarios.
Riesgo residual	Bajo

H-05 — Bypass de filtro de extensión en formulario de carga de archivos

Campo	Valor
Fase	Explotación
Descripción	La aplicación web de Vulniversity (directorio /internal, descubierto por Gobuster) bloqueaba la extensión .php, pero no otras extensiones ejecutables equivalentes reconocidas por el motor PHP de Apache. Se renombró una web shell PHP a shell.phtml, se subió exitosamente y se ejecutó accediendo a su ruta, obteniendo ejecución remota de código como el usuario www-data.
Componente afectado	Formulario de carga de archivos (/internal)
Categoría (OWASP / CWE)	CWE-434 (Unrestricted Upload of File with Dangerous Type) / OWASP A05:2021 (Security Misconfiguration)
CVE	No aplica (falla de configuración de la aplicación)
CVSS estimado	Crítico
Evidencia	Mensaje "Success" al subir shell.phtml; listener nc -lvnp recibiendo shell inversa como www-data; comandos y resultado en bitacora/gobuster_vulniversity.txt y bitacora/nmap_vulniversity.txt.
Herramienta utilizada	Gobuster, navegador web, netcat, php-reverse-shell.php
Impacto en la Tríada CIA	Confidencialidad, Integridad, Disponibilidad
Salvaguarda propuesta	Validar tipo de archivo por contenido (no solo por extensión), usar listas blancas estrictas de extensiones, deshabilitar la ejecución de scripts en el directorio de uploads, y aislar el servicio en un contenedor

Campo	Valor
Riesgo residual	con mínimos privilegios. Medio

H-06 — Escalada de privilegios mediante binario SUID (systemctl)

Campo	Valor
Fase	Post-explotación
Descripción	Tras obtener acceso como <code>www-data</code> , la enumeración de binarios con bit SUID reveló que <code>/bin/systemctl</code> tenía el bit SUID activado, lo que no corresponde a su configuración estándar. Esto permitió crear un servicio <code>systemd</code> malicioso que otorga el bit <code>setuid</code> a <code>/bin/bash</code> , habilitando una shell de root mediante <code>/bin/bash -p</code> .
Componente afectado	Binario <code>/bin/systemctl</code> (permisos SUID indebidos)
Categoría (OWASP / CWE)	CWE-269 (Improper Privilege Management)
CVE	No aplica
CVSS estimado	Crítico
Evidencia	Listado de binarios SUID (<code>find / -perm -4000</code>); creación y habilitación del servicio malicioso; shell de root confirmada con <code>whoami</code> ; <code>flag root.txt</code> obtenida.
Herramienta utilizada	<code>find</code> , <code>systemctl</code>
Impacto en la Tríada CIA	Confidencialidad, Integridad, Disponibilidad
Salvaguarda propuesta	Auditar periódicamente binarios con bit SUID/SGID y remover permisos innecesarios; aplicar hardening de sistema (CIS Benchmarks) en el despliegue de servidores.
Riesgo residual	Bajo

4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	3	H-04, H-05, H-06
Alto	3	H-01, H-02, H-03
Medio	0	—
Bajo	0	—
Total	6	H-01 a H-06

El relevamiento sobre las tres salas evidencia un patrón recurrente de debilidades en **gestión de credenciales** (contraseñas débiles, claves sin protección adecuada, credenciales en texto plano) y en **gestión de privilegios** (sudo sin restricciones, binarios SUID mal configurados), además de una falla puntual de **validación de entrada** en la capa web (carga de archivos). La combinación de estos hallazgos permitió, en dos de las tres salas, una escalada completa hasta privilegios de root.

5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones), priorizadas por criticidad

1. **(Crítico)** Eliminar archivos con credenciales en texto plano (pass . bak y similares) y migrar a un gestor de secretos.
2. **(Crítico)** Revisar y corregir permisos SUID/SGID de binarios del sistema, removiendo los que no sean estrictamente necesarios.
3. **(Crítico)** Implementar validación de tipo de archivo por contenido real (magic bytes) en todo formulario de carga, y deshabilitar la ejecución de scripts dentro del directorio de uploads.
4. **(Alto)** Forzar políticas de contraseñas robustas y bloqueo de cuentas tras intentos fallidos en todos los servicios de autenticación (SSH incluido).
5. **(Alto)** Corregir permisos de archivos sensibles (claves privadas) a 600 y exigir passphrases de alta entropía.
6. **(Alto)** Restringir sudoers al principio de mínimo privilegio, evitando entradas ALL sin justificación.

Recomendaciones administrativas (políticas y procesos)

- Incorporar revisiones periódicas de configuración (hardening) como parte del ciclo de vida de los servidores.
 - Establecer una política formal de gestión de contraseñas y claves criptográficas.
 - Capacitar al personal técnico en buenas prácticas de seguridad en despliegues Linux y aplicaciones web.
 - Incluir pruebas de penetración periódicas (al menos anuales) dentro del plan de seguridad de INSECUR S.A.
-

6. Protocolo de Contingencia

Escenario de falla

Durante la etapa de explotación del formulario de carga de archivos (hallazgo H-05) y la escalada de privilegios vía SUID (H-06), existe el riesgo de que, en un entorno de producción real, acciones equivalentes sean ejecutadas por un atacante real, comprometiendo totalmente el servidor y los servicios que aloja (en este caso, un servicio web expuesto a Internet).

Impacto sobre la continuidad del negocio

Un compromiso total del servidor (acceso root) afectaría la disponibilidad del servicio web expuesto, la confidencialidad de cualquier dato almacenado en el sistema y la integridad de la configuración del servidor. De tratarse de un sistema productivo de INSECUR S.A., esto podría implicar la interrupción del servicio al público por un período indeterminado hasta su reconstrucción, además de un posible compromiso de datos de clientes.

Plan de respuesta

1. **Activación:** La falla se detecta mediante monitoreo de integridad de archivos, alertas de IDS/IPS ante tráfico anómalo (shells inversas, conexiones salientes no habituales) y revisión de logs de autenticación con intentos o accesos no reconocidos.
2. **Contención:** En los primeros 15 minutos se debe aislar el servidor afectado de la red (segmentación/desconexión), revocar credenciales potencialmente comprometidas y preservar evidencia (logs, memoria) antes de cualquier remediación.
3. **Recuperación:** Restaurar el servicio desde una imagen/backup limpio y verificado, aplicando previamente los parches de los hallazgos detectados (eliminación de SUID indebidos, corrección del filtro de uploads, rotación de credenciales) antes de reconectar el servidor a producción.
4. **Comunicación:** Notificar a dirección de TI y a la gerencia de INSECUR S.A. de forma inmediata; si hubo exposición de datos de clientes, notificar también a las autoridades competentes y a los clientes afectados conforme a la normativa vigente de protección de datos.
5. **Post-mortem:** Documentar la línea de tiempo del incidente, causa raíz (vinculada a los hallazgos H-01 a H-06), acciones tomadas y lecciones aprendidas, actualizando el plan de seguridad y las políticas internas en consecuencia.

RTO y RPO estimados

- **RTO (Recovery Time Objective):** 4 horas (tiempo estimado para restaurar el servicio desde backup y aplicar parches críticos).
 - **RPO (Recovery Point Objective):** 24 horas (basado en una frecuencia de backup diaria del servidor).
-

Anexos

Anexo A — Bitácora de comandos

Los archivos de bitácora se encuentran en la carpeta bitacora/ del branch pizarro-enrique:

- bitacora/nmap_basicpentesting.txt
- bitacora/gobuster_basicpentesting.txt
- bitacora/hydra_jan.txt
- bitacora/hydra_kay.txt
- bitacora/basic_pentesting.txt (resumen manual de la resolución)

- bitacora/nmap_vulniversity.txt
- bitacora/gobuster_vulniversity.txt

Anexo B — Capturas de pantalla

Carpeta evidencias/ del branch pizarro-enrique, incluyendo:

- evidencias/fundamentals_completada.png
- evidencias/basicpentesting_completada.png
- evidencias/vulniversity_completada.png

Anexo C — Hashes de las flags obtenidas

ID	SHA-256
H-04 (Basic Pentesting — contraseña final de pass.bak)	3ffd53ec80858f9ddcd75d69102724ab1bc1020855fff924227f618c4bfccf57
H-06 (Vulniversity — user.txt)	d324bd433001e5bdfe39e04d794539c15b51982a5bf6fc78efea46369b7bf956
H-06 (Vulniversity — root.txt)	cfbcb740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8

(Hashes calculados con `echo -n "<valor>" | sha256sum`, conforme al mecanismo de control de autenticidad de la guía oficial.)

Anexo D — Declaración ética

Declaro que todas las actividades descritas en este informe se realizaron dentro del alcance autorizado por la cátedra, exclusivamente sobre los entornos de laboratorio virtualizados de TryHackMe, con fines académicos, sin afectar sistemas reales ni de terceros.

Firma del estudiante: Enrique Pizarro **Fecha:** 08/10/2026